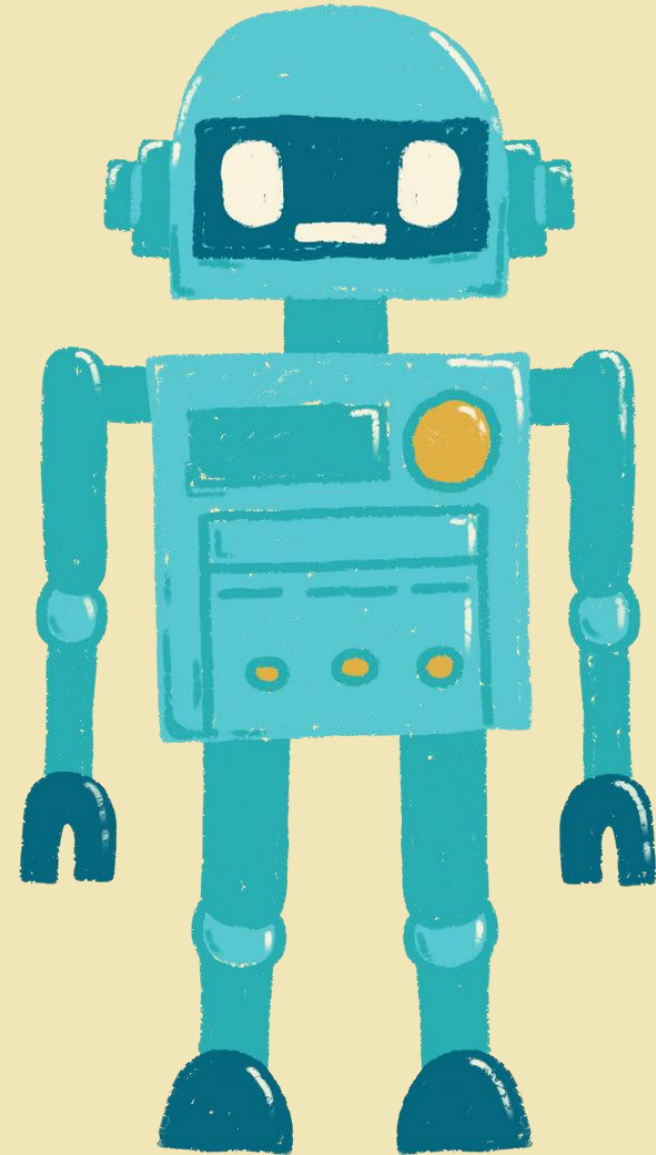


Making AI Eat Frameworks...
So, I Don't Have To

Anthony Porter





Who Am I?

Anthony Porter

Cloud Security Architect

Canon Business Services ANZ

Blog: <https://www.securingm365.com>

LinkedIn: <https://www.linkedin.com/in/AnthonyAntoPorter>

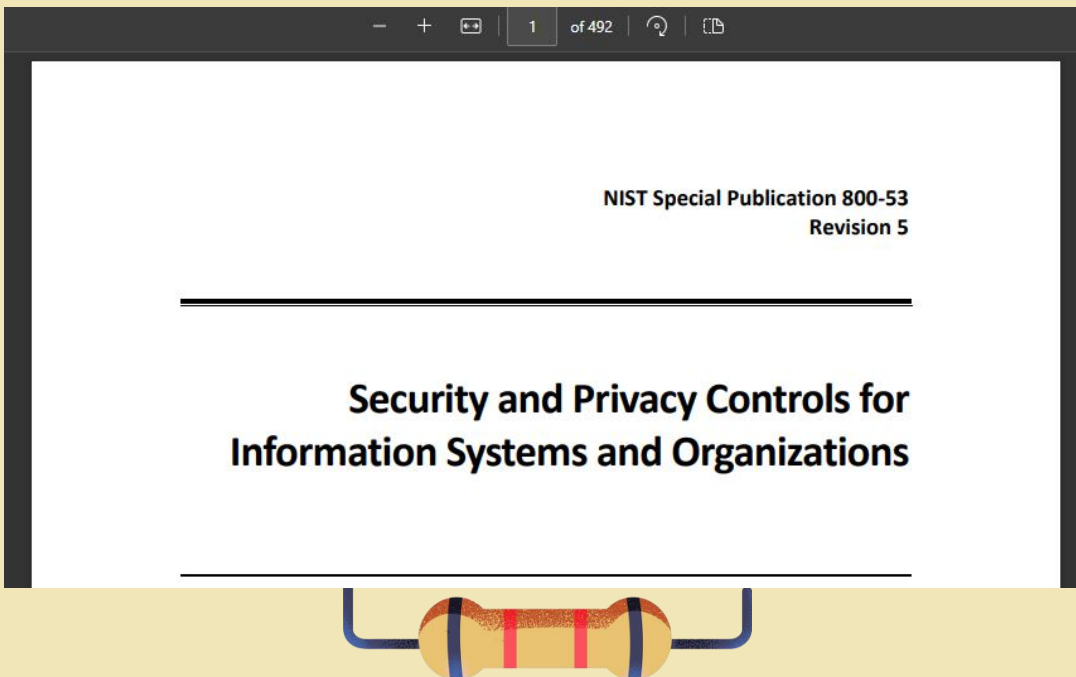
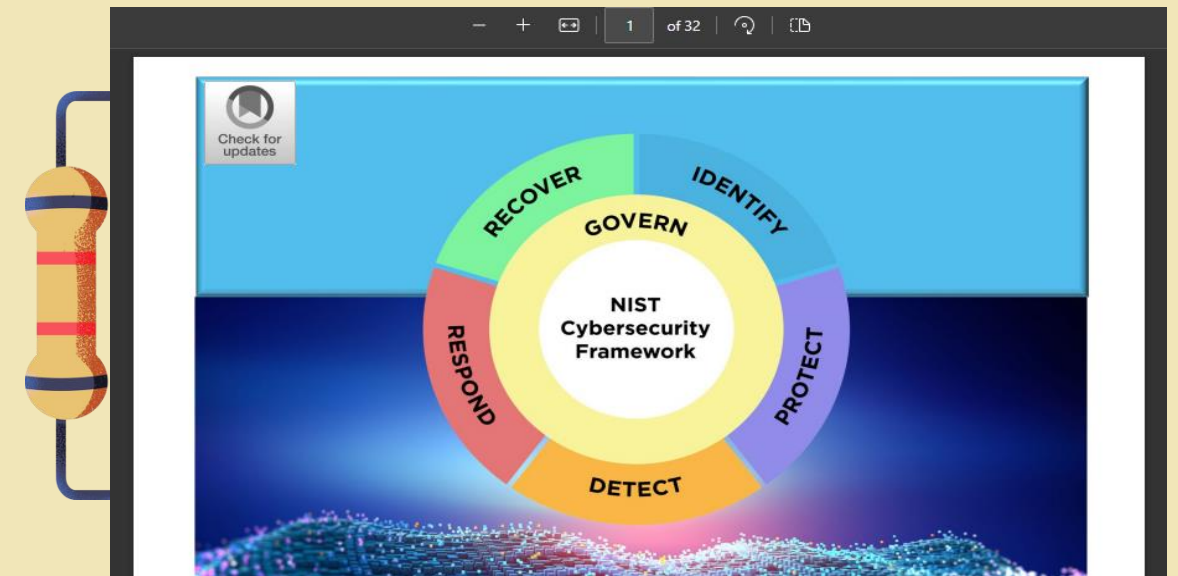
GitHub: <https://www.github.com/AntoPorter>

Podcast: Out of Band: A Microsoft Security Podcast



The Dilemma

- Compliance demands keep growing.
- Frameworks are long and complex.
- Time seems to always be limited.



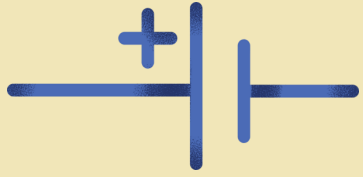


The Lightbulb Moment

While Messing around with the bare basics with Copilot Studio:

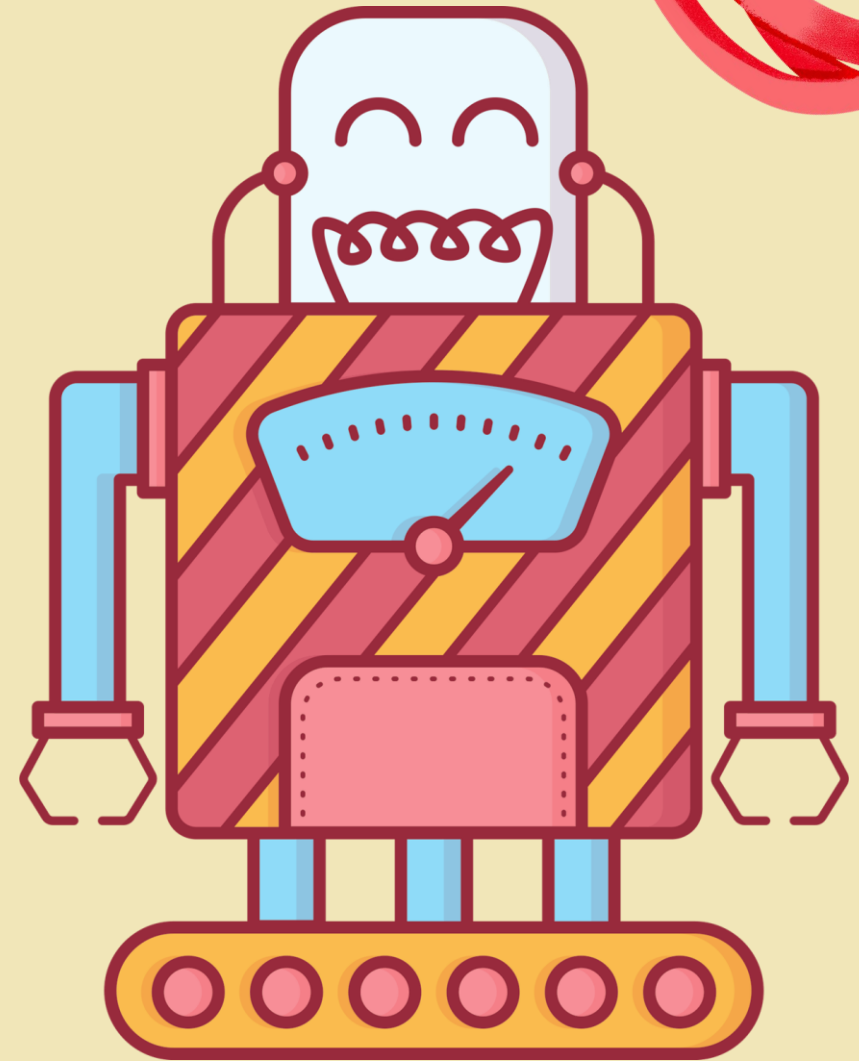
- I was playing with the idea that I could have it respond to me with specific websites contents, generic really, the basics...
- Then came the realisation that I could have the ability to limit a smaller amount of Knowledge Sources based on Topic contents...
- I then was being pulled away from my "Fun", by yet another query towards a set of technical frameworks, in this case, ISM...

That was my lightbulb moment...



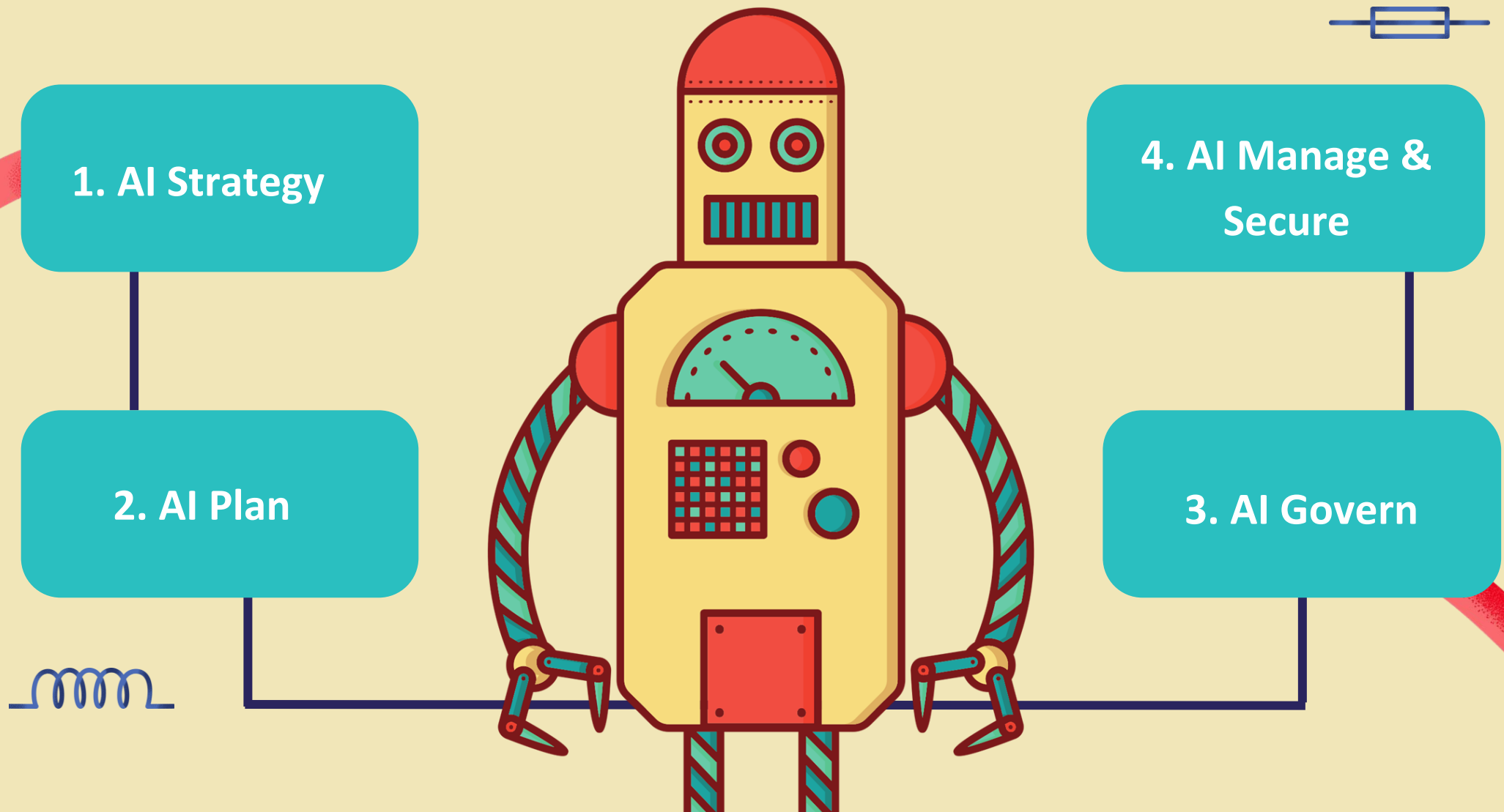
That wasn't going to
stop me. I needed a
way forward...

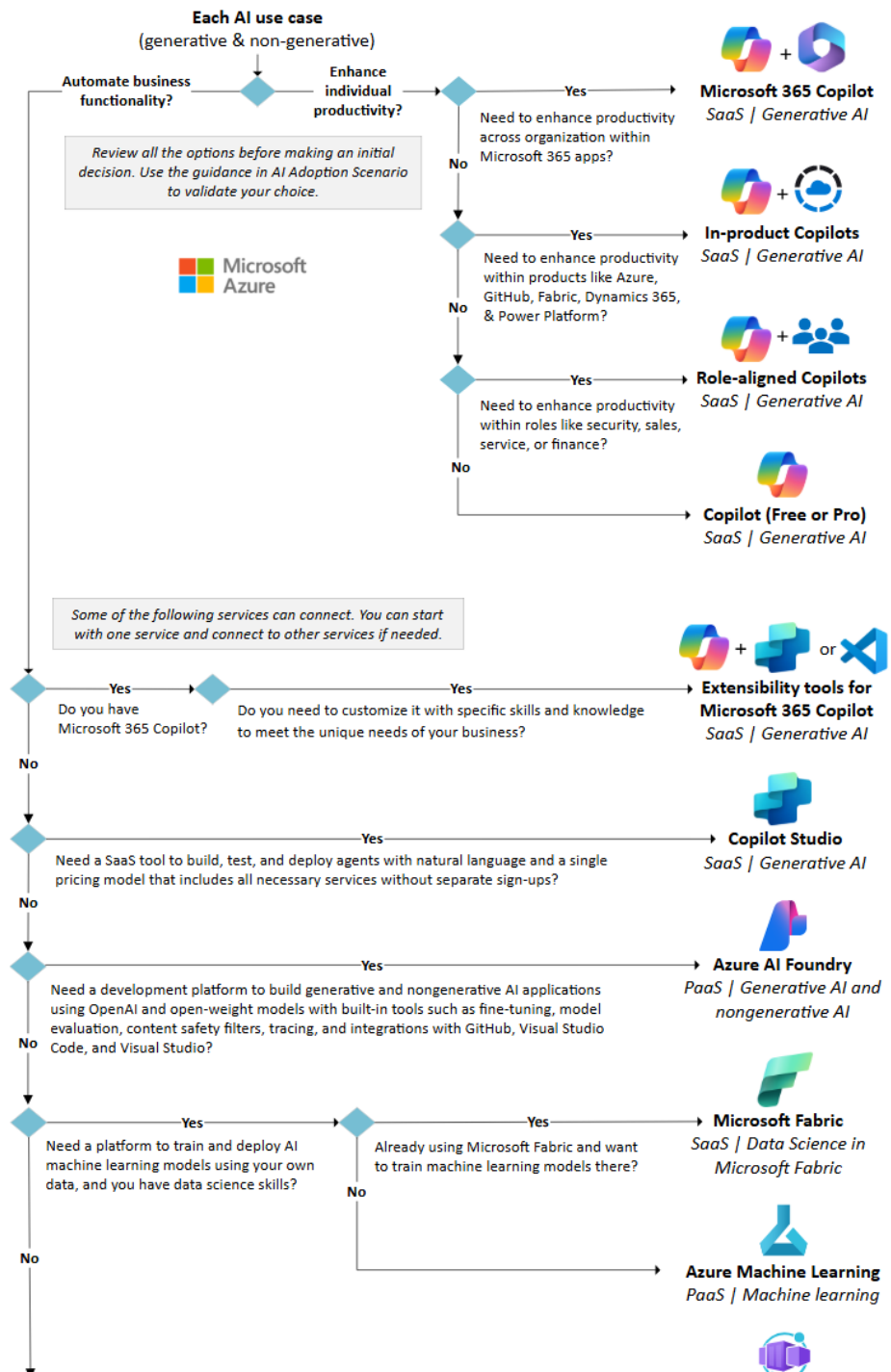
And It needed to be
done correctly...



AI Adoption Journey

My 4 Part "Plan"
Who said structure was a bad thing?





The Strategic Decision

Step 1 of “The Plan”
How am I going to even do this?

- **Know your AI tools**
Understand what each tool does, and how it could fit your needs.
- **Prep your data well**
Clean, structure, and ready your data for AI use.
- **Define your goal**
Decide what you want your AI agent to deliver.

In My Case, I went with Copilot Studio.



Planning the Knowledge Sources

Step 2 of “The Plan”
Define the Data Sources & Key Metrics



Relevant Data Only!

Only relevant and up-to-date insights were included as knowledge sources, making sure the data was precise and useful.

No Customer Data!

No customer data was to be included either, this ensures that there was to be no risks associated.

Exclude GenAI Answers!

Generative AI answers were strictly prohibited to maintain the integrity and accuracy of the data.





Defining Key Metrics Criteria

Proof of Concept

The POC design focused on defining questions for the Agent using 1 Security Framework as the initial knowledge source.

Influencing Factors

The approach was influenced by specific circumstances that led to the POC setup to begin with.

Security Controls and Applications

The goal was simple...
To identify and address specific questions regarding specific security framework controls and their applications.





The Questions Defined

1

"What are all the Security Framework Controls associated to Windows 11 Hardening"

2

"What are all the Security Framework Controls associated to Multi-Factor Authentication"

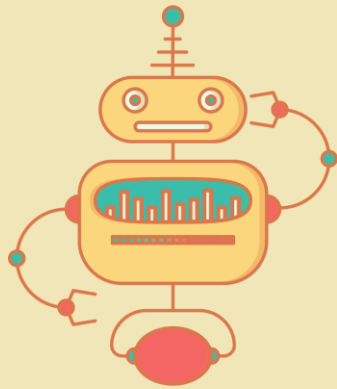
3

"What is ISM control ISM-0123, Is it included in Essential Eight, and what is its application within an Organisation"



Govern AI Risk

Step 3 of “The Plan”
Keeping my Agent from becoming my Enemy



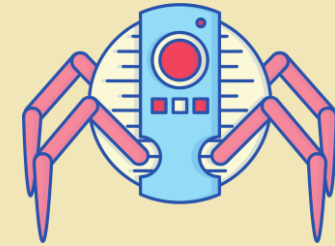
Understand the AI workloads

To mitigate AI risks, you must understand your AI workloads.



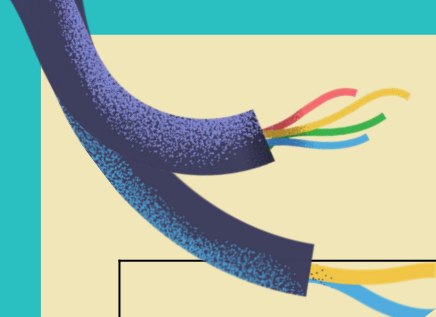
Use Responsible AI principles to identify risks

These principles provide a framework for assessing AI risks.



Identify AI Risks

Start by evaluating the security risks of AI workloads, including potential data breaches, unauthorized access, or misuse



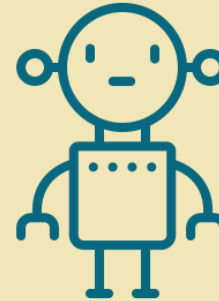
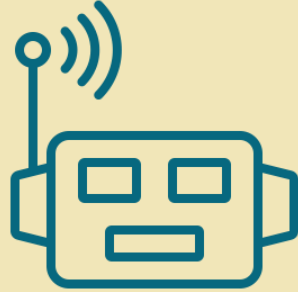
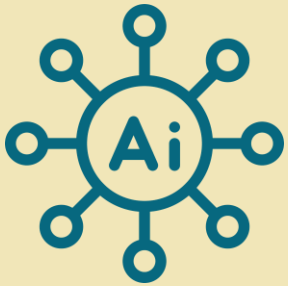
Responsible AI Principals



Responsible AI Principal	A Simple Definition	An example of a Risk Assessment Question
AI Privacy and Security	AI workloads should respect privacy and be secure.	How might my AI Agent handle sensitive data or become vulnerable to security breaches?
Reliability and Safety	AI workloads should perform safely and reliably.	In what situations could my AI Agent fail to operate safely or produce unreliable outcomes?
Fairness	AI workloads should treat people equitably.	How could my AI Agent lead to unequal treatment or unintended bias in decision-making?
Inclusiveness	AI workloads should be inclusive and empowering.	How might certain groups be excluded or disadvantaged in the design or deployment of my AI Agent?
Transparency	AI workloads should be understandable.	What aspects of my AI's decision-making could be difficult for users to understand or explain?
Accountability	People should be accountable for AI workloads.	Where could accountability be unclear or difficult to establish in the development or use of AI?

Managing AI Workloads

Step 4 of “The Plan”
Once its Built, Then What?



Structured Operational Processes

Organize each stage of the AI lifecycle.

Deployment Governance

Control and guide AI rollouts effectively.

Comprehensive Monitoring Practices

Detect and resolve issues early.

Alignment with Business Objectives

Keep AI reliable, efficient, and aligned with goals.



Monitoring Key Metrics

User engagement

Number of conversations and messages

Topic usage

Which topics are triggered most frequently

Resolution rate

How often users get their questions answered

Escalation rate

How often conversations are transferred to humans

Satisfaction

User feedback on their experience



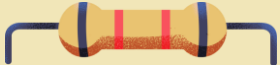


Governance and Security Best Practices

Implementing Governance

- Clarify ownership and responsibility.
 - Separate dev, test, and prod.
 - Track and manage changes.
 - Document content and configuration standards.
- 

Security Considerations

- Control what your Copilot can access.
 - Setup secure login methods.
 - Ensure you meet all regulatory requirements.
 - Monitor and log access and changes.
- 

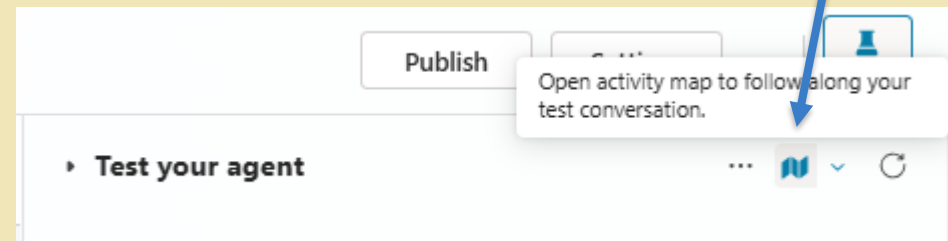
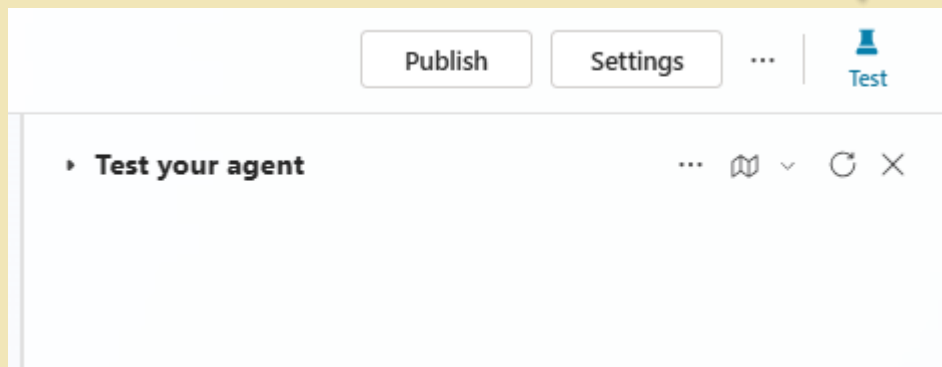
AI security posture management

- **Defender for Cloud** secures AI workloads across Azure, AWS, and GCP.
 - Discovers AI workloads and finds vulnerabilities.
 - Provides security recommendations to reduce risk.
- 

Testing My Copilot Agent

The Final Part of “The Plan”
Does it Work? and what if it Doesn’t?

Testing Your Copilot	Debugging Issues
1. Click the Test your Copilot button in the upper right 2. In the test chat panel, interact with your Copilot 3. Verify that triggers work as expected 4. Check that variables are stored and used correctly 5. Test edge cases and unexpected inputs	When something doesn't work as expected: 1. Review the conversation trace in the test panel 2. See which topics were triggered 3. Examine variable values at each step 4. Check for error messages in action nodes

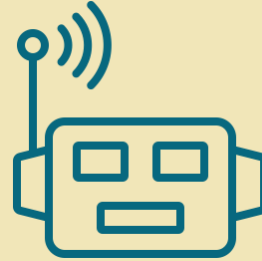


The Timeline of the Agent So Far



Defining the Copilot Agent Strategy

- Confirmed the Toolset
- Defined only Public Documentation
- No Gen AI / No Internet Access
- Defined the Agents use cases.



Defining the Copilot Agent Knowledge

- Download the latest Framework(s) documentation.
- Fact Check material.
- Collate them into "Collections".
- Tweak Agent to my liking.

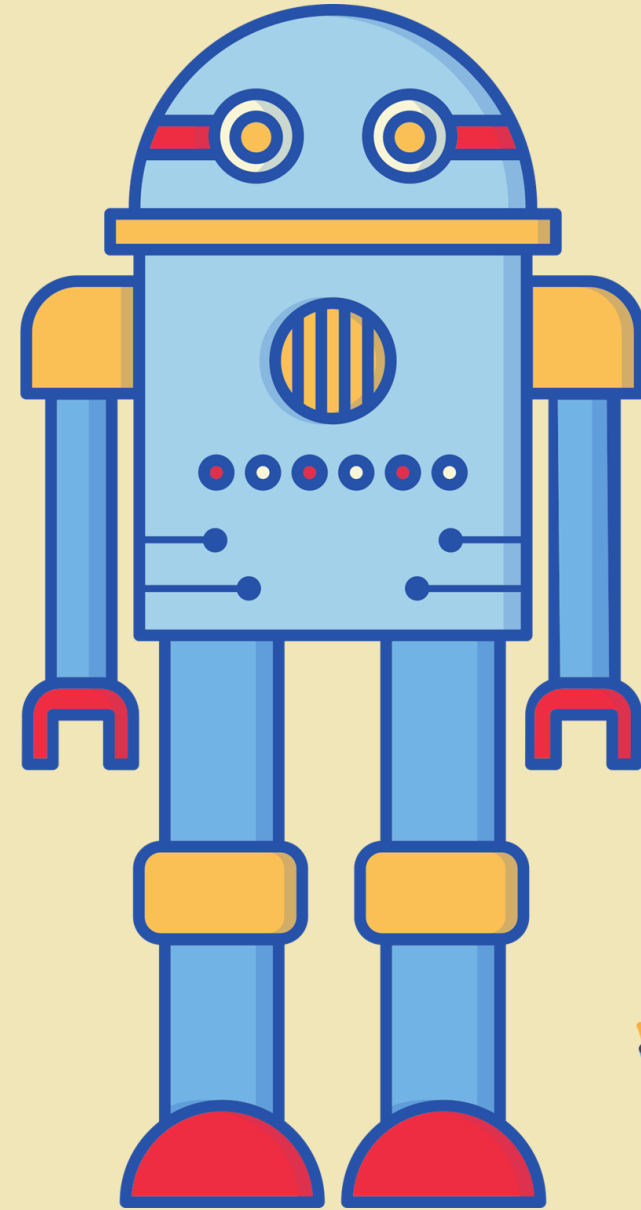


Defining the Copilot Agent Governed, Managed and Secure

- Track, record, and remediate issues.
- Set up analytics and performance tracking.
- Ensure security and governance standards.
- Validate against criteria and new knowledge sources.
- Deploy to sources that meet business needs.

So, After All That:
Where Am I Now?

And the steps to get there...



Details

Cancel

Save

Name *

Security Framework Assistant



 Change icon

Used to represent the agent. Icon should be in PNG format and

Instructing the Agent

Description ⓘ

I am the Security Framework Assistant, here to provide comprehensive information, interactive examples, resource links, and compliance checklists for NIST CSF 2.0, NIST SP 800-53, Information Security Manual (ISM) & Essential 8, ISO 27001, and more.

General instructions ⓘ

{x} f_x

Provide Detailed Information:

Framework Confirmation: Ensure that you confirm the request against every Security Framework present, when requested.

Control Identifier: Clearly specify each and every control identifier when asked a question (e.g., NIST CSF ID.AM-1, ISO 27001 A.5.1.1).

Description: Offer a detailed description of what the control entails.

Knowledge Sources

+ Add knowledge

Search knowledge

All Files Public website

🔄 Last refreshed 50 minutes ago

Name	Type	Available to	Last modified	Status
 Australian Cyber Security Centre (...)	 Public website	 Security Framework A...	Anthony Po...	 Ready
 Collection of files: CIS	 Files	 Security Framework A...	Anthony Po...	 Ready
 Collection of files: NIST SP 800-53	 Files	 Security Framework A...	Anthony Po...	 Ready
 Collection of files: Information Securit...	 Files	 Security Framework A...	Anthony Po...	 Ready
 Collection of files: NIST CSF 2.0	 Files	 Security Framework A...	Anthony Po...	 Ready

← Collection of files: Information Security Manual (ISM)

Name *

54/100

Collection of files: Information Security Manual (ISM)

Description * ⓘ

391/2500

This collection contains comprehensive information and resources related to the Information Security Manual (ISM). It includes official documents, guidelines, best practices, and implementation strategies to help users understand and apply the ISM in their organizations. The ISM is designed to provide a framework for managing security risks and ensuring compliance with security standards.

Instructions (preview) ⓘ



Provide an overview of the ISM, including its purpose and structure.
Include detailed descriptions, examples, and best practices for each section of the ISM.
Offer implementation guidelines and real-world examples.
Map ISM controls to other frameworks like NIST CSF 2.0, ISO 27001, and Essential 8.
Include links to official documents and resources.
List keywords for recognition.
Enable the Agent to answer questions and provide updates.

438/500

Files

Edit files



System security plan annex template (June 2025).xlsx



Cloud controls matrix template (June 2025).xlsx



Information security manual (June 2025).pdf



Fine Tuning the Knowledge Sources

Content Moderation on High

Moderation

Content moderation level

Lower moderation increases the risk of harmful content in your agent's responses. Higher moderation lowers that risk, but may reduce the number of responses. [Learn more](#)

High



The moderation levels range from **Lowest** to **Highest**.

The **lowest** level generates the most answers, but they might contain harmful content.

The **highest** level of content moderation generates fewer answers and applies a stricter filter to restrict harmful content.

User Feedback

Preview

Collect user reactions to agent messages

Users can give thumbs-up or thumbs-down and an optional comment. Feedback goes to your organization, not to Microsoft.

[Learn more](#)

☒ On

Enable a Feedback
Mechanism

Topic (Knowledge Sources) Refinement

Trigger

The agent chooses [Edit](#)

Describe what the topic does

This tool can handle queries like these:
internet security manual, show me the internet security manual, ISM guide, how to use the ISM, internet security instructions

Create generative answers

Input

(x) LastMessage.Text string ...

Data sources [Edit](#)

Search for content or provide your own context, use OpenAI to create a summarized response using the provided data.

[Learn more](#)

Knowledge sources

Get search results from the knowledge sources using selected mode.

☒ Search only selected sources

☐	Name	
☒	Australian Cyber Security C	
☐	Collection of files: CIS	
☐	Collection of files: NIST SP 800	
☒	Collection of files: Information	
☐	Collection of files: NIST CSF 2.0	

[+ Add knowledge](#)

Prevent Hallucination

Knowledge

Use general knowledge

The foundational knowledge that the generative AI was trained on. To ground your agent only with your specific knowledge sources, turn this off. [Learn more](#)

☐ off

Use information from the Web

Let your agent browse the Web using Bing Web search. [Learn more](#)

☐ off

Telemetry offers insights into your agent by tracking:

- Logged messages and events sent to and from your agent
- Topics to be triggered during user conversations
- Custom telemetry events that can be sent from your topics

Enable App Insights

Advanced

Application Insights

Automatically send telemetry for your agent into an Application Insights resource. You can also log custom telemetry events from within your topics. [Learn more](#)

Connection string

.....



[Where can I find my connection string?](#)

Advanced options



Log activity ⓘ

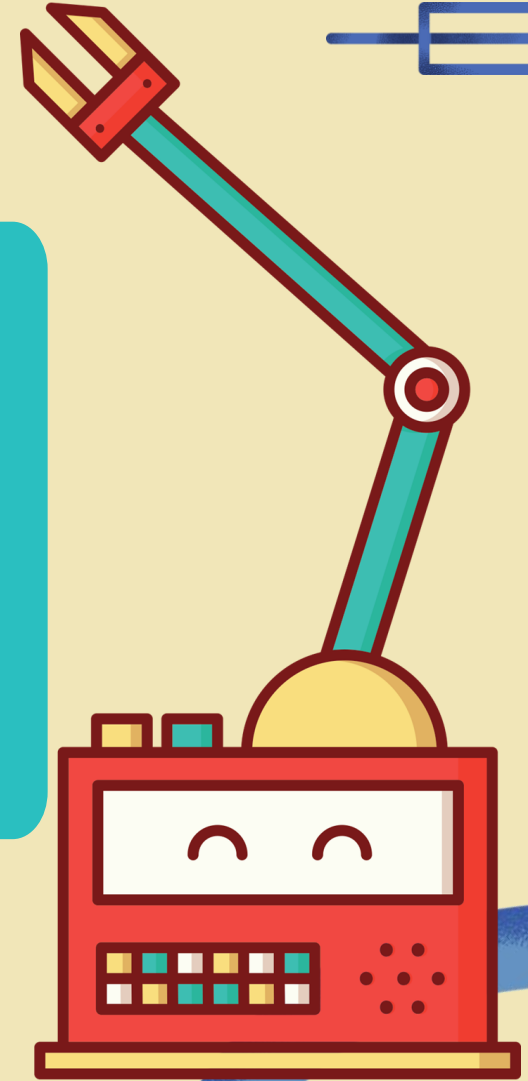
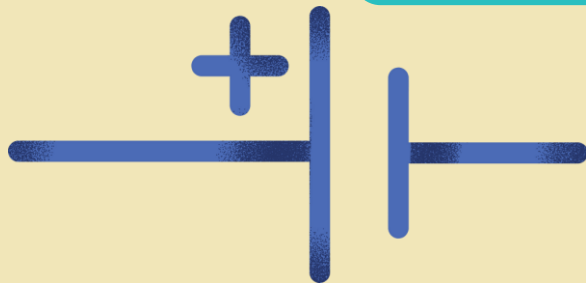


Log sensitive activity properties ⓘ



Log node tools ⓘ

And with that...
Here were the Test Results!



"What are all the Security Framework Controls associated to Windows 11 Hardening"

Test your agent

... ⌵ ↺ ✕

What are all the security framework controls that apply to Windows 11 Hardening?

9 minutes ago

Security Framework Controls for Windows 11 Hardening

NIST Cybersecurity Framework (CSF) 2.0

- **Identify (ID):**
 - **ID.AM-1:** Physical devices and systems within the organization are inventoried.
 - **ID.AM-2:** Software platforms and applications within the organization are inventoried.
- **Protect (PR):**
 - **PR.AC-1:** Identities and credentials are managed for authorized devices and users.
 - **PR.DS-1:** Data-at-rest is protected.
 - **PR.DS-2:** Data-in-transit is protected.
 - **PR.IP-1:** A baseline configuration of information technology/industrial control systems is created and maintained.
 - **PR.IP-3:** Configuration change control processes are in place.
 - **PR.MA-1:** Maintenance and repair of organizational assets are performed and logged in a timely manner, with approved and controlled tools.
- **Detect (DE):**
 - **DE.CM-1:** The network is monitored to detect potential cybersecurity events.
 - **DE.CM-7:** Monitoring for unauthorized personnel, connections, devices, and software is performed.
- **Respond (RS):**
 - **RS.RP-1:** Response plan is executed during or after an incident.
- **Recover (RC):**
 - **RC.RP-1:** Recovery plan is executed during or after a cybersecurity incident.

NIST SP 800-53

- **AC-1:** Access Control Policy and Procedures.
- **CM-2:** Baseline Configuration.
- **CM-3:** Configuration Change Control.
- **CM-6:** Configuration Settings.
- **SI-2:** Flaw Remediation.
- **SI-3:** Malicious Code Protection.

Ask a question or describe what you need

0/2000

🔗 ➤

Make sure AI-generated content is accurate and appropriate before using. [See terms](#)

"What are all the Security Framework Controls associated to Multi-Factor Authentication"

Test your agent

... ⌵ ↺ ✕

What are the all the security framework controls associated to Multi-Factor Authentication?

2 minutes ago

Security Framework Controls Related to Multi-Factor Authentication

NIST CSF 2.0

- **PR.AA-03:** Users, services, and hardware are authenticated.
 - **Ex1:** Require multifactor authentication.
 - **Ex2:** Enforce policies for the minimum strength of passwords, PINs, and similar authenticators.
 - **Ex3:** Periodically reauthenticate users, services, and hardware based on risk (e.g., in zero trust architectures).
 - **Ex4:** Ensure that authorized personnel can access accounts essential for protecting safety under emergency conditions ①.

NIST SP 800-53

- **IA-02:** Identification and Authentication (Organizational Users).
 - Implement multifactor authentication for network access to privileged accounts.
- **IA-03:** Device Identification and Authentication.
 - Implement multifactor authentication for network access to non-privileged accounts.
- **IA-05:** Authenticator Management.
 - Manage the lifecycle of authenticators used in multifactor authentication.
- **IA-07:** Cryptographic Module Authentication.
 - Use cryptographic modules for multifactor authentication.
- **IA-08:** Identification and Authentication (Non-Organizational Users).
 - Implement multifactor authentication for network access to non-organizational users ①.

ISO/IEC 27001:2022

- **Annex A Controls: 5.15:** Authentication information management.
 - Implement multifactor authentication to protect authentication information.
- **Annex A Controls: 5.16:** Access control to networks and network services.
 - Use multifactor authentication for access control.
- **Annex A Controls: 5.17:** User access management.
 - Ensure multifactor authentication is used for user access management.
- **Annex A Controls: 5.18:** System and application access control.
 - Implement multifactor authentication for system and application access control ①.

ISM (Information Security Manual)

- **ISM-1504:** Multi-factor authentication is used to authenticate users to their organization's online services that process, store or communicate their organization's sensitive data.
- **ISM-1679:** Multi-factor authentication is used to authenticate users to third-party online services that process, store or communicate their organization's sensitive data.
- **ISM-1680:** Multi-factor authentication (where available) is used to authenticate users to third-party

Ask a question or describe what you need

0/2000

🗨️ ▶

Make sure AI-generated content is accurate and appropriate before using. [See terms](#)

"What is ISM control ISM-0123, Is it included in Essential Eight, and what is its application within an Organisation"

• Test your agent



What is ISM control ISM-0123, Is it included in Essential Eight, and what is its application within an Organisation

Just now

ISM Control ISM-0123

Control Identifier: ISM-0123

Description:

- **Reporting Cybersecurity Incidents:** This control mandates that cybersecurity incidents must be reported to the Chief Information Security Officer (CISO) or one of their delegates as soon as possible after they occur or are discovered. This allows senior management to assess the impact on the organization and oversee any cybersecurity incident response activities.
- **Legislative Obligations:** Organizations should be aware of any legislative obligations regarding the reporting of cybersecurity incidents to authorities.

Applicability:

- **NC, OS, P, S, TS:** This control is applicable to various classifications of information and systems, including National Security (NC), Official (OS), Protected (P), Secret (S), and Top Secret (TS).

Essential Eight:

- **Maturity Levels:** ML2, ML3
- **Description:** The Essential Eight Maturity Model supports the implementation of prioritized mitigation strategies to protect against cyber threats. The control ISM-0123 is mapped to the Essential Eight Maturity Levels 2 and 3, indicating its relevance in achieving a higher level of cybersecurity maturity.

Purpose:

- Ensures timely reporting of cybersecurity incidents to facilitate effective incident management and compliance with legislative requirements.

Application within an Organization:

- **Incident Reporting:** Organizations must establish procedures for the prompt reporting of cybersecurity incidents to the CISO or their delegates. This ensures that incidents are managed effectively and that senior management is informed to oversee the response.
- **Compliance:** Organizations must be aware of and comply with any legislative requirements for reporting cybersecurity incidents to relevant authorities.
- **Maturity Levels:** By aligning with the Essential Eight Maturity Levels 2 and 3, organizations can enhance their cybersecurity posture and better protect against threats.

If you have any further questions or need additional information, feel free to ask!

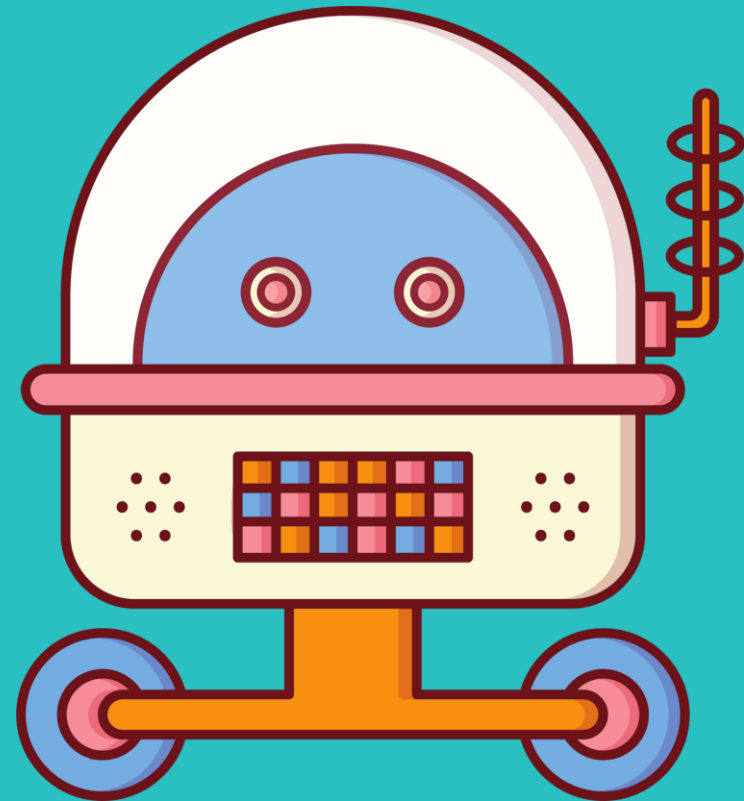
Ask a question or describe what you need

0/2000



So... What's Next?

Expand on Frameworks
Split Technical from Governance
Test out Actions capabilities



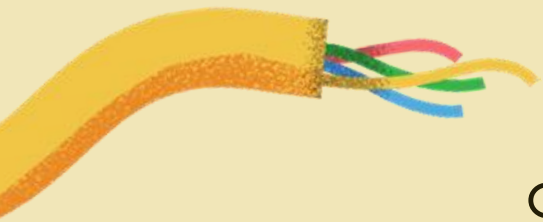


Anthony Porter
Microsoft Intune & Defender
XDR Guru | Host: Out of Ban...



LET'S WRAP THINGS UP

Any Questions?



Anthony Porter
Cloud Security Architect
Canon Business Services ANZ

Blog: <https://securingm365.com>

LinkedIn: <https://www.linkedin.com/in/AnthonyAntoPorter>

GitHub: <https://www.github.com/AntoPorter>

Podcast: Out of Band: A Microsoft Security Podcast

